Insecure by Design: A Hands-On Learning Platform for Web Security Training

Progress Report 5

CSIS 4495-003 | Applied Research Project

Winter 2026

Instructor: Arasanipalai Kandhadai, Padmapriya

Thilan Udahage Don | 300398798

Work Logs (Mar 10 – Mar 16)

Date	Number of Hours	Description of Work
Mar 17	2	Began implementing the CSRF and IDOR vulnerability modules. Researched common CSRF attack patterns and IDOR exploitation approaches suitable for a Spring Boot MVC application. Planned the challenge structure and controller design for both modules. Also applied polish to the user profile progress tracker, refining the completion status display and ensuring all challenge modules are correctly reflected on the profile page.
Mar 18	2.5	Implemented CsrfController with an intentionally vulnerable state-change endpoint that does not validate CSRF tokens, and created csrf.html demonstrating how a forged cross-site request can be executed. Implemented IdorController with endpoints exposing user resources by predictable numeric IDs without authorization checks, and created idor.html demonstrating parameter manipulation for unauthorized data access. Used Claude to assist with the controller and template structure.
Mar 19	2	Added "Why It Worked" Explainer sections to the file upload, broken authentication, CSRF, and IDOR modules. Wrote explanatory content for each vulnerability and integrated the same JavaScript reveal pattern established in the SQLi module. Fixed progress tracker persistence bugs where completed levels were not correctly reflected on the profile page for the file upload and broken authentication modules.
Mar 20	2	Friday team meeting with Allwyn. Reviewed CSRF and IDOR implementations, discussed Allwyn's work this week, and aligned on final integration and polish tasks. Reviewed the updated homepage and OWASP page together.
Mar 21	1.5	Saturday team meeting with Allwyn. Performed a full walkthrough of the platform, identified remaining bugs, and divided final polish tasks. Updated the homepage layout, refreshed the OWASP reference page with accurate descriptions for all implemented vulnerability types, and updated the shared layout navigation to include links to the CSRF and IDOR modules.
Mar 23	2	Completed final bug fixes across modules. Performed end-to-end testing of all challenge modules, Explainer sections, and the profile tracker. Finalized and checked in all implementation files and Progress Report 5.

Summary Description

During this reporting period, I worked across several areas: implementing the CSRF and IDOR vulnerability modules, expanding the "Why It Worked" Explainer to additional modules, polishing the user profile progress tracker, fixing bugs across the platform, and updating the homepage, layout, and OWASP reference page. I used Claude to assist with the CSRF and IDOR controller and template structure, then reviewed, adapted, and tested all generated code against our existing project architecture.

For the CSRF module, I implemented CsrfController with an intentionally vulnerable state-change endpoint that omits CSRF token validation, along with a challenge template demonstrating how a forged cross-site request can be executed. For the IDOR module, I implemented IdorController with endpoints that expose user resources via predictable numeric IDs without authorization checks, demonstrating how parameter manipulation leads to unauthorized data access.

I also extended the "Why It Worked" Explainer to the file upload, broken authentication, CSRF, and IDOR modules, applying the same JavaScript reveal pattern established in PR4. I resolved progress tracker bugs where completed levels were not being correctly persisted for the file upload and broken authentication modules, and refreshed the homepage, shared layout navigation, and OWASP reference page to reflect all implemented modules. Allwyn focused on designing UAT test cases for this period. Regular Friday and Saturday team meetings were held on March 20 and 21.

Repo Check-In of Implementation Completed

Since the previous progress report, I have checked the following files and updates into the GitHub repository under the Implementation folder:

- Created CsrfController.java with a vulnerable state-change endpoint that omits CSRF token validation.
- Created csrf.html Thymeleaf template demonstrating a forged cross-site request challenge.
- Created IdorController.java with endpoints exposing user resources via predictable IDs without authorization checks.
- Created idor.html Thymeleaf template demonstrating parameter manipulation for unauthorized data access.

- Added "Why It Worked" Explainer sections to fileupload.html, broken authentication template, csrf.html, and idor.html.
- Fixed progress tracker persistence bugs in the file upload and broken authentication modules.
- Updated profile.html to correctly reflect completion status for all modules.
- Updated index.html (homepage) and shared layout template with links to CSRF and IDOR modules.
- Updated OWASP reference page with descriptions for all implemented vulnerability types.
- Progress Report 5 (this document) checked into the ReportsAndDocuments folder.

All files were committed individually under my own GitHub account, in compliance with the requirement for individual contributions.

AI Use Section

Table of AI Tools and Specific Use

AI Tool Name	Version, Account Type	Specific feature for which the AI tool was used	Value Addition - What value did you add over and above what AI did for you?
Claude (Anthropic)	Claude Sonnet 4.6, free	Used to assist with coding the CSRF and IDOR vulnerability modules — specifically CsrfController.java, IdorController.java, csrf.html, and idor.html Thymeleaf templates.	Reviewed all generated code for correctness against our Spring Boot project structure. Adapted controller method signatures and routing to match our existing conventions, verified that the intentionally vulnerable logic behaved as intended for each module, and performed end-to-end testing of both challenges.

Appendix

Prompt History

Prompt 1 (Claude, Sonnet 4.6 free):

"I am building a Spring Boot MVC cybersecurity training platform with Thymeleaf. I need to implement two intentionally vulnerable challenge modules: one for CSRF (a state-change endpoint that does not validate CSRF tokens) and one for IDOR (endpoints that expose user resources by

predictable numeric IDs without authorization checks). Can you help me create CsrfController and IdorController with appropriate endpoints, and csrf.html and idor.html Thymeleaf templates that demonstrate each vulnerability?"